

REST API Design Guide

REST Principles

REST APIs use HTTP methods: GET for reading, POST for creating, PUT for updating, DELETE for removing. Resources are identified by URLs. Stateless communication means each request contains all needed information. Use proper HTTP status codes: 200 OK, 201 Created, 400 Bad Request, 404 Not Found, 500 Server Error.

Authentication

JWT tokens enable stateless authentication. Include the token in Authorization header as Bearer token. Refresh tokens allow getting new access tokens without re-login. OAuth 2.0 enables third-party authentication. Always use HTTPS to protect tokens in transit. Set appropriate token expiration times.

Rate Limiting

Rate limiting prevents API abuse and ensures fair usage. Implement per-user and per-IP limits. Return 429 Too Many Requests when limits are exceeded. Include rate limit headers: X-RateLimit-Limit, X-RateLimit-Remaining, X-RateLimit-Reset. Use Redis for distributed rate limiting across multiple servers.

Error Handling

Return consistent error responses with error code and message. Use appropriate HTTP status codes for different error types. Include request ID in responses for debugging. Log errors with context for monitoring. Never expose internal error details to clients. Validate input and return 400 for invalid requests.

API Versioning

Version your API to avoid breaking changes. URL versioning: `/api/v1/users` is simple and visible. Header versioning keeps URLs clean. Semantic versioning communicates change impact. Maintain backward compatibility when possible. Deprecate old versions with clear timelines and migration guides.